

Governança de modelos, mudanças e incidentes de IA

Pílula de Principal Engineering - como transformar risco de IA em controles operáveis, evidência e decisões reversíveis

O QUE ESTA PÍLULA TREINA

Não responder "governança é com risco". Mostrar que a arquitetura já nasce com ownership, registro, validação, promoção, rollback e resposta a incidentes.

1. A frase-mestra

Modelo não é arquivo; é uma decisão em produção. O risco real não está apenas nos pesos: ele aparece no conjunto de dados, prompt, RAG, tools, roteamento, threshold, operador humano, dependências e contexto de uso.

Resposta de Principal: "Eu governaria o sistema completo e o ciclo de vida, com controle proporcional ao risco. Cada mudança precisa ter owner, evidência, versão, critério de promoção, telemetria e caminho de rollback."

2. ROTA: quatro letras para lembrar sob pressão

R	O	T	A
Risco Qual decisão o sistema influencia? Quem pode ser afetado? O que é irreversível?	Ownership Quem responde pelo produto, modelo, dados, tool, política, aprovação e incidente?	Teste Qual evidência valida qualidade, segurança, viés, robustez, custo e explicabilidade?	Acompanhamento Como promover, observar, detectar degradação, interromper e aprender?

Regra de retenção: em qualquer pergunta de governança, fale ROTA antes de mencionar comitê ou ferramenta. Isso mantém a resposta técnica e evita burocracia vazia.

3. O que precisa ser versionado

O erro comum é versionar apenas o modelo. Para IA aplicada em banco ou seguros, o pacote que pode mudar o comportamento inclui:

ARTEFATO	EXEMPLO DE MUDANÇA	RISCO QUE PRECISA SER REAVALIADO
Modelo	trocar fornecedor, versão ou quantização	qualidade, privacidade, latência, custo, comportamento inesperado
Instruções	alterar system prompt, template ou formato de saída	aderência, jailbreak, conteúdo indevido, interpretação da tool
Conhecimento	novo corpus, chunking, embedding, reranker ou filtro de vigência	proveniência, atualização, acesso indevido, citação incorreta
Ferramentas	novo endpoint, escopo de escrita ou parâmetro	ação não autorizada, efeito duplicado, exposição de dados
Políticas	threshold, guardrail, roteamento ou regra de abstention	falso positivo, falso negativo, aumento silencioso de autonomia
Contexto operacional	mudança de volume, público, produto ou canal	drift, distribuição fora do conjunto de validação, SLO quebrado

Armadilha: "O modelo não mudou, então não precisamos revalidar." **Upgrade:** "A unidade de mudança é o sistema de IA. Se prompt, corpus, tool, policy ou distribuição mudou, o gate de risco decide o nível de revalidação."

4. O registro mínimo de um sistema de IA

Identidade

- caso de uso e decisão influenciada
- owner técnico, owner de negócio e owner de risco
- classificação de dados e usuários afetados

Contrato

- entradas, saídas, fontes de verdade e limites
- SLO, custo por operação e taxa aceitável de abstention
- ações permitidas e ações proibidas

Evidência

- conjunto dourado e data de corte
- eval por segmento e casos adversariais
- red team, revisão humana e decisão de aprovação

Proveniência

- modelo, prompt, corpus, tool e dependências
- licença, fornecedor, região e retenção
- hash ou identificador imutável dos artefatos

Operação

- dashboards, alertas e correlação de sessão
- runbook, fallback e kill switch
- janela de revisão e condição de aposentadoria

Decisão

- risco residual aceito e por quem
- restrições temporárias e data para reavaliar
- ADR com alternativas e consequências

5. Arquitetura de promoção: do rascunho à produção

O control plane guarda metadados, políticas e evidências. O data plane executa apenas artefatos aprovados. Nenhum agente deveria descobrir em runtime que está usando uma combinação nunca validada.



ETAPA	GATE	DECISÃO
Draft	artefatos identificados, owner e risco preliminar	pode testar em ambiente isolado
Evaluated	eval funcional, segurança, custo, latência e segmentos críticos	há evidência suficiente para revisão?
Approved	risco residual, limitações, monitoramento e rollback documentados	quem aceita o risco e por quanto tempo?
Canary	tráfego limitado, shadow ou grupo controlado, alertas ativos	o comportamento real confirma o offline?
Active	SLO, drift, incidentes, custo e outcome dentro do contrato	continuar, ampliar ou reavaliar
Degraded	threshold excedido ou incidente confirmado	abster, fallback, rollback, pausar ou aposentar

6. Caso de entrevista: IA para triagem de fraude em sinistros

CASO DE BANCO E SEGUROS

RISCO FINANCEIRO

CONTROLE PROPORCIONAL

"Como você colocaria um modelo de IA para priorizar investigação de sinistros suspeitos?"

Risco: a saída é uma priorização, não prova de fraude. O sistema pode influenciar tempo de atendimento e investigação, mas não deve negar automaticamente um sinistro sem fluxo aprovado, evidência e revisão adequada.

Ownership: produto responde pelo outcome; engenharia pelo runtime e SLO; dados pelo dataset e qualidade; risco/model validation pela independência da validação; segurança e privacidade pelos controles; operações pelo processo humano.

Teste: comparar com baseline histórico e revisão humana, medir precisão e recall por segmento, testar explicabilidade operacional, avaliar vazamento de dados, calibrar threshold para o custo de falso positivo e falso negativo, e executar cenários de drift.

Acompanhamento: iniciar em shadow, exibir evidências ao investigador, limitar o volume de casos, monitorar distribuição e taxa de override, registrar decisões, manter fallback determinístico e definir kill switch. Se o perfil dos sinistros mudar, congelar expansão e revalidar.

Frase forte: "Eu não aprovaria um modelo porque a métrica média subiu. Eu aprovaria uma versão de sistema com escopo, evidência por segmento, risco residual aceito, trilha de decisão e uma forma testada de parar sem interromper o serviço inteiro."

7. Incidente de IA: o que o Principal faz

1. **Conter:** reduzir autonomia, pausar promoção, ativar fallback ou bloquear a tool de escrita.
2. **Preservar evidência:** versão do pacote, prompt, contexto, documentos recuperados, tool calls, decisão humana e métricas.
3. **Classificar impacto:** cliente afetado, dados expostos, decisão financeira, duração e blast radius.
4. **Comunicar:** owner, risco, segurança, privacidade, produto e operações com fatos e incertezas explícitos.
5. **Recuperar:** rollback para última combinação aprovada ou workflow determinístico conhecido.

6. **Aprender:** corrigir a causa sistêmica: eval ausente, contrato fraco, alerta tardio, owner indefinido ou rollout amplo demais.

Distinção importante: rollback técnico não é encerramento do incidente. Em ambiente regulado, ainda é preciso estabelecer impacto, comunicação, evidência e mudança preventiva.

8. Três linhas de defesa, sem burocracia

LINHA	RESPONSABILIDADE	EVIDÊNCIA QUE DEIXA
1. Construção e operação	time que cria, implanta, observa e corrige	testes, dashboards, runbook, incidentes e ADRs
2. Risco e validação independente	desafiar premissas, revisar método, avaliar risco residual e aprovar exceções	parecer, limitações, aprovação e plano de monitoramento
3. Auditoria	avaliar se o sistema de controles funciona ao longo do tempo	achados, rastreabilidade, evidência de execução e remediação

Como Principal, você não substitui essas funções. Você constrói interfaces técnicas para que elas consigam trabalhar: registry, contratos, evidências, telemetria, ownership e mecanismos de promoção.

9. Perguntas de entrevista e respostas curtas

"Quem aprova um modelo?"

Depende do risco e da política, mas a aprovação precisa ser explícita, com owner, escopo, evidência, limitações, risco residual e validade. O time técnico recomenda; não deve aprovar sozinho o risco de negócio.

"Como você evita que governança mate a velocidade?"

Classifico mudanças por risco. Mudança reversível e baixo impacto usa paved road e automação; mudança com escrita financeira, dados sensíveis ou efeito irreversível exige gate mais forte. Governança boa reduz espera e retrabalho.

"O que dispara revalidação?"

Modelo, prompt, corpus, retriever, tool, política, threshold, público, canal, volume ou dependência que altere o comportamento. A regra é baseada em impacto, não em qual arquivo mudou.

"Qual a diferença entre observabilidade e governança?"

Observabilidade mostra o que aconteceu; governança define quem pode mudar, com qual evidência e quem aceita o risco. Uma sem a outra deixa o sistema cego ou imóvel.

"Como explicaria uma decisão de IA?"

Explicação operacional não é inventar uma justificativa pós-hoc. Mostro fontes, sinais relevantes, versão do sistema, política aplicada, grau de confiança, limitações e caminho de revisão humana.

"Quando aposentar um caso de uso?"

Quando o outcome não paga o custo e o risco, o processo mudou, a qualidade caiu, a fonte deixou de ser confiável ou a alternativa determinística é superior. Critério de kill deve existir antes do entusiasmo.

10. Resposta de 60 segundos

"Eu começaria pelo ROTA: risco, ownership, teste e acompanhamento. Primeiro classificaria qual decisão o sistema influencia e o que é irreversível. Depois registraria owners do produto, modelo, dados, tools e risco. A unidade de mudança seria o sistema completo, não apenas o modelo: prompt, corpus, retriever, tool, policy e distribuição também podem exigir revalidação. Eu promoveria por estados - draft, evaluated, approved, canary e active -, sempre com evidência, telemetria, rollback e kill switch. Em um incidente, conteria autonomia, preservaria a trilha, classificaria impacto, comunicaria os responsáveis e só depois faria a correção definitiva. Assim, velocidade vem da automação dos gates de baixo risco, não da ausência de controle."

11. Exercício de 15 a 20 minutos

- [] Escreva ROTA de memória e explique cada letra em uma frase.
- [] Escolha um caso seu e liste seis artefatos que podem mudar sem alterar os pesos do modelo.
- [] Desenhe a máquina de estados Draft -> Evaluated -> Approved -> Canary -> Active -> Rollback.
- [] Defina três alertas que disparariam rollback e dois que apenas abririam investigação.
- [] Fale a resposta de 60 segundos sem usar as palavras "comitê" ou "compliance". Depois acrescente onde entram risco e auditoria.

Teste final: se a sua resposta não disser quem pode mudar, qual evidência autoriza a promoção e como parar o sistema, ainda falta engenharia de produção.

12. Referências oficiais

A ideia central desta pílula é compatível com referências oficiais que tratam risco de IA como ciclo de vida contínuo, com govern, map, measure e manage, e com orientações de governança e resiliência para instituições financeiras.

- [NIST AI Risk Management Framework](#) - framework voluntário para incorporar confiabilidade no desenho, desenvolvimento, uso e avaliação.
- [NIST AI RMF Generative AI Profile](#) - riscos e ações ao longo do ciclo de vida de sistemas generativos.

- [BIS Project Noor](#) - transparência, fairness e robustez de modelos em supervisão financeira.
- [BIS - Governance of AI adoption in central banks](#) - governança, gestão de riscos e uso das três linhas de defesa.

Como usar: 15 minutos de leitura, 5 minutos de recuperação sem consulta, 2 minutos de resposta falada.

Frase para levar: modelo não é arquivo; é uma decisão em produção.